



ACTIVIDAD 18

Análisis de intrusiones con el modelo diamante

CON V: Seguridad Informática
Servando López Contreras

Álvarez Aquino Enrique – 177071

Arellano Wratny Elisa Alejandra – 177339

López Alemán Emiliano – 182883

Portales Pérez Luis Gabriel – 174278

Rodríguez Rivera José Vicente – 179954

Análisis de intrusiones con el modelo diamante

1. Introducción

En la actualidad, las organizaciones dependen ampliamente de infraestructuras digitales para el almacenamiento, procesamiento y transmisión de información crítica, lo que ha incrementado la exposición a amenazas cibernéticas cada vez más sofisticadas. Los ataques informáticos modernos no solo buscan comprometer sistemas, sino también mantener persistencia, evadir mecanismos de seguridad y desplazarse lateralmente dentro de las redes corporativas. Debido a ello, resulta fundamental contar con metodologías que permitan analizar y correlacionar eventos de seguridad para comprender el comportamiento de los adversarios y responder de manera efectiva ante incidentes de ciberseguridad.

El Modelo Diamante de Análisis de Intrusiones constituye una metodología ampliamente utilizada en el ámbito de la ciberseguridad para estructurar eventos de ataque a partir de cuatro elementos principales: adversario, capacidad, infraestructura y víctima. Este modelo facilita la identificación de relaciones entre los componentes involucrados en una intrusión, permitiendo comprender cómo operan los atacantes y cuáles son los recursos utilizados durante una campaña maliciosa. Asimismo, su integración con la metodología Cyber Kill Chain permite analizar las diferentes fases del ataque y determinar la progresión de las actividades realizadas por el adversario dentro de la infraestructura comprometida.

En la presente actividad se desarrolla el análisis de un escenario de intrusión utilizando el Modelo Diamante y la Cyber Kill Chain como herramientas de correlación y análisis. A partir del escenario propuesto, se identifican los elementos fundamentales del ataque, se clasifican los eventos detectados dentro de las fases de la Kill Chain y se analizan los hilos de actividad relacionados con el compromiso de múltiples víctimas dentro de la red organizacional. Finalmente, se realiza una interpretación técnica de los eventos con el propósito de comprender el comportamiento del atacante y la evolución del incidente dentro del entorno corporativo.

El desarrollo de este análisis permite fortalecer la comprensión de modelos de inteligencia y análisis de amenazas en ciberseguridad, así como la capacidad de identificar patrones de ataque y correlacionar eventos asociados a campañas de intrusión avanzadas.

2. Objetivos

2.1 Objetivo General

Aplicar el Modelo de Diamante del Análisis de Intrusiones para identificar, estructurar y correlacionar eventos de ciberataques, relacionándolos con la Cadena de Eliminación Cibernética (Cyber Kill Chain) para comprender el comportamiento del adversario.

2.2 Objetivos Específicos

- Identificar y clasificar los elementos del modelo: Adversario, Capacidad, Infraestructura y Víctima
- Analizar un incidente realista y descomponerlo en eventos de intrusión
- Relacionar los eventos con fases de la Kill Chain y detectar patrones de ataque

3. Marco Teórico

3.1 ¿Qué es un incidente de ciberseguridad?

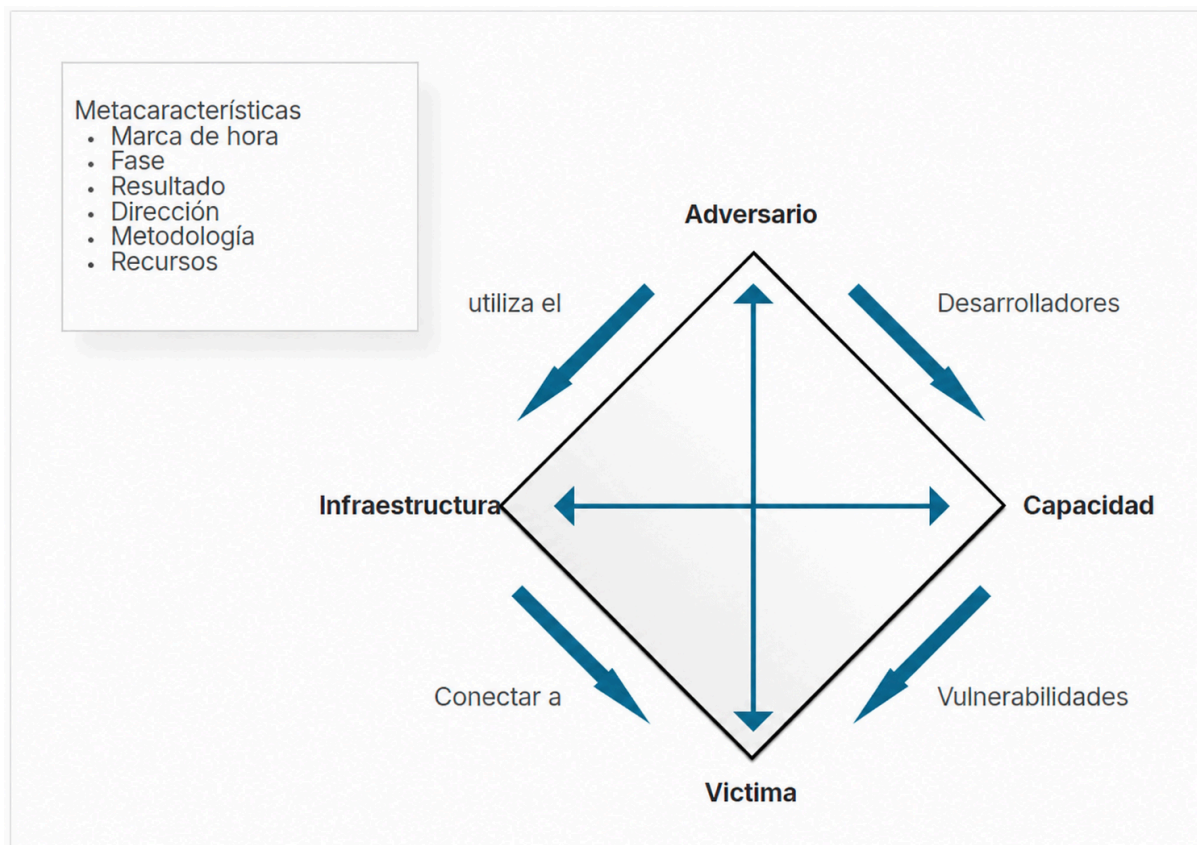
Un incidente de ciberseguridad es cualquier evento que compromete o amenaza la confidencialidad, integridad o disponibilidad de la información y de los sistemas tecnológicos de una organización. Estos incidentes pueden originarse por actividades maliciosas, errores humanos, fallos técnicos o vulnerabilidades explotadas por atacantes.

Los incidentes de ciberseguridad incluyen actividades como infecciones por malware, ataques de phishing, accesos no autorizados, robo de información, ataques de denegación de servicio (DoS), ransomware y explotación de vulnerabilidades en sistemas o redes. La gravedad de un incidente depende del impacto generado sobre los activos digitales, los servicios afectados y la información comprometida.

Dentro del ámbito organizacional, la detección temprana y el análisis de incidentes son fundamentales para reducir daños, restaurar operaciones y evitar futuras intrusiones. Para ello, se utilizan metodologías y modelos de análisis que permiten comprender el comportamiento del atacante, identificar los recursos comprometidos y establecer mecanismos de respuesta adecuados.

De acuerdo con el Instituto Nacional de Estándares y Tecnología (NIST), un incidente de seguridad informática puede definirse como una violación o amenaza inminente de violación de políticas de seguridad, prácticas aceptables o controles de seguridad establecidos dentro de un sistema de información.

3.2 ¿Qué es el Modelo Diamante?



El Modelo Diamante de Análisis de Intrusiones es una metodología de ciberseguridad diseñada para analizar y correlacionar eventos relacionados con ataques informáticos. Fue desarrollado con el objetivo de proporcionar una estructura lógica que permita comprender cómo interactúan los diferentes elementos involucrados en una intrusión.

Este modelo establece que todo evento de intrusión puede representarse mediante cuatro componentes principales: el adversario, la capacidad, la infraestructura y la víctima. La relación entre estos elementos permite identificar patrones de ataque, rastrear actividades maliciosas y comprender el comportamiento del atacante dentro de una campaña de intrusión.

El Modelo Diamante es ampliamente utilizado en actividades de análisis forense, inteligencia de amenazas y respuesta a incidentes, ya que facilita la correlación de evidencias y la identificación de relaciones entre múltiples eventos de seguridad. Además, puede integrarse con otras metodologías, como la Cyber Kill Chain y el marco MITRE ATT&CK, para obtener una visión más completa del ciclo de ataque.

El modelo recibe el nombre de “diamante” debido a la representación gráfica de sus cuatro elementos principales conectados entre sí, formando una estructura de análisis relacional.

Elementos principales del Modelo Diamante:

- Adversario
- Capacidad

- Infraestructura
- Víctima

3.3 Elementos del Modelo Diamante

El Modelo Diamante se basa en cuatro componentes fundamentales que permiten describir y analizar un incidente de intrusión. Cada elemento representa una parte esencial del ataque y la relación entre ellos ayuda a comprender cómo opera el adversario.

3.3.1 Adversario

El adversario es el actor responsable de realizar la intrusión o actividad maliciosa. Puede tratarse de un ciberdelincuente individual, grupos organizados, hacktivistas, amenazas internas o incluso actores patrocinados por estados.

El objetivo principal del adversario puede variar dependiendo de la motivación del ataque. Algunos buscan obtener beneficios económicos mediante robo de información o ransomware, mientras que otros persiguen espionaje, sabotaje, interrupción de servicios o acceso persistente a sistemas críticos.

Durante el análisis de incidentes, identificar al adversario permite comprender sus tácticas, técnicas y procedimientos (TTPs), así como relacionar el ataque con campañas previas o grupos conocidos.

Ejemplos de adversarios:

- Grupos de ransomware
- Amenazas persistentes avanzadas (APT)
- Hackers independientes
- Empleados internos maliciosos

3.3.2 Capacidad

La capacidad representa las herramientas, técnicas o recursos utilizados por el adversario para ejecutar el ataque. Esto incluye malware, exploits, scripts maliciosos, técnicas de phishing, herramientas de acceso remoto y métodos de evasión de seguridad.

Las capacidades utilizadas reflejan el nivel técnico y sofisticación del atacante. Algunas intrusiones utilizan herramientas simples y automatizadas, mientras que otras emplean malware avanzado diseñado específicamente para una organización objetivo.

El análisis de capacidades permite identificar:

- Tipo de malware utilizado
- Vulnerabilidades explotadas
- Métodos de persistencia
- Técnicas de movimiento lateral

- Herramientas de Command and Control (C2)

3.3.3 Infraestructura

La infraestructura corresponde a los recursos tecnológicos utilizados por el adversario para ejecutar y mantener la intrusión. Incluye servidores, dominios, direcciones IP, servicios de alojamiento, redes comprometidas y sistemas de comunicación utilizados durante el ataque.

La infraestructura permite al atacante distribuir malware, establecer comunicación remota con sistemas infectados y ocultar su identidad. En muchos casos, los adversarios utilizan múltiples servidores y dominios para dificultar la detección y el rastreo de sus actividades.

El análisis de infraestructura es importante porque ayuda a:

- Identificar servidores de Command and Control (C2)
- Detectar conexiones sospechosas
- Correlacionar ataques similares
- Bloquear direcciones IP maliciosas
- Rastrear campañas de intrusión

3.3.4 Víctima

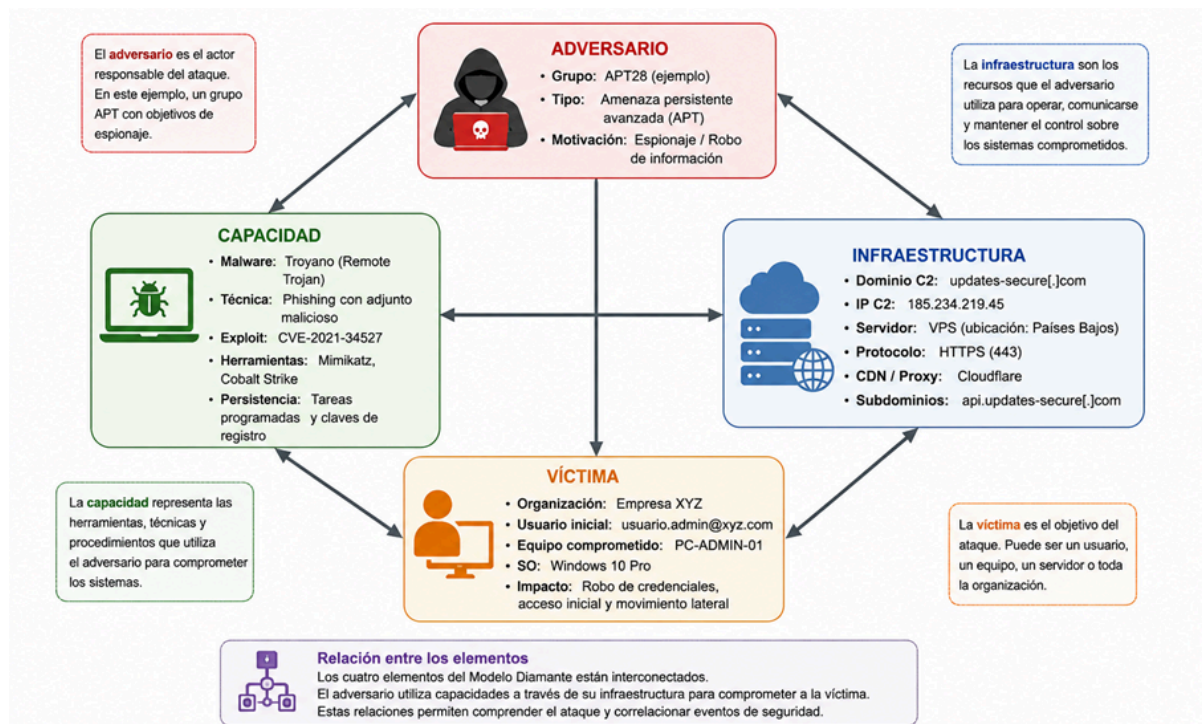
La víctima es el objetivo afectado por el ataque. Puede tratarse de usuarios individuales, equipos, servidores, aplicaciones o incluso organizaciones completas.

En muchos casos, los atacantes seleccionan víctimas específicas con base en información estratégica, privilegios de acceso o valor de los datos almacenados. Las víctimas pueden ser comprometidas mediante phishing, explotación de vulnerabilidades o robo de credenciales.

El análisis de la víctima permite determinar:

- Sistemas afectados
- Impacto del incidente
- Información comprometida
- Nivel de acceso obtenido por el atacante
- Posibles riesgos para la organización

Dentro de una campaña de intrusión, puede existir una víctima primaria inicial y posteriormente múltiples víctimas secundarias afectadas por movimiento lateral dentro de la red.



3.4 ¿Qué es Cyber Kill Chain?

La Cyber Kill Chain, desarrollada por Lockheed Martin, es un modelo que describe las etapas de un ataque cibernético desde el reconocimiento inicial hasta la consecución de los objetivos del adversario. Esta metodología permite a los analistas de seguridad identificar y detener las intrusiones en diferentes niveles de progresión.

Las fases que componen este modelo son:

- **Reconocimiento (Reconnaissance):** El atacante selecciona su objetivo, investiga vulnerabilidades y recolecta información (correos electrónicos, infraestructuras, tecnologías utilizadas).
- **Armamento (Weaponization):** Se combina una carga maliciosa (malware) con un exploit para crear un "entregable", como un documento de Office con macros maliciosos.
- **Entrega (Delivery):** Transmisión del arma al entorno de la víctima. Los métodos comunes incluyen el envío de correos electrónicos de phishing o el uso de unidades USB infectadas.
- **Explotación (Exploitation):** El código malicioso se activa y aprovecha una vulnerabilidad en el sistema operativo o una aplicación para obtener control sobre el dispositivo.
- **Instalación (Installation):** El adversario instala un acceso persistente (como un troyano o backdoor) en el sistema de la víctima para mantener el control incluso tras un reinicio.

- **Comando y Control (C2):** El sistema comprometido establece un canal de comunicación con la infraestructura externa del atacante para recibir instrucciones remotas.
- **Acciones sobre los Objetivos (Actions on Objectives):** El atacante cumple su propósito final, que puede incluir el robo de datos, el cifrado de archivos (ransomware) o el movimiento lateral hacia otros servidores.

4. Caso Práctico

4.1 Comprensión del Modelo Diamante

Elemento	Descripción	Ejemplo práctico
Adversario	Actor responsable de ejecutar la intrusión o actividad maliciosa dentro de la infraestructura objetivo. Puede tratarse de grupos APT, ciberdelincuentes o amenazas internas.	Grupo APT especializado en espionaje y compromiso de redes corporativas mediante campañas de phishing.
Capacidad	Herramientas, técnicas o recursos utilizados por el atacante para ejecutar el ataque y mantener persistencia.	Malware con comunicación C2, técnicas de phishing y herramientas de movimiento lateral.
Infraestructura	Recursos tecnológicos utilizados por el adversario para distribuir malware y controlar sistemas comprometidos.	Dominios maliciosos, servidores C2, direcciones IP externas y VPS utilizados para comunicación remota.
Víctima	Usuario, equipo, servidor u organización afectada por la intrusión.	Usuario con privilegios administrativos y equipos internos comprometidos dentro de la red corporativa.

4.2 Análisis del Evento

Durante las actividades de monitoreo de seguridad dentro de una organización, se detectó comportamiento anómalo en un equipo perteneciente a la red corporativa. El análisis inicial

permitió identificar la presencia de malware ejecutándose en el sistema comprometido, el cual establecía comunicación con dominios asociados a infraestructura de Command and Control (C2). Asimismo, se observó que dichos dominios resolvían hacia múltiples direcciones IP externas, generando conexiones salientes desde varios hosts internos de la organización. Los registros de tráfico y eventos de red evidenciaron actividad repetitiva hacia estas direcciones externas, sugiriendo un posible compromiso adicional de otros equipos dentro de la infraestructura corporativa. Finalmente, mediante consultas WHOIS y análisis de direcciones IP, se logró identificar un posible origen relacionado con la infraestructura utilizada por el atacante, permitiendo asociar el incidente con actividades típicas de campañas de intrusión y comunicación remota maliciosa.

Metacaracterística	Descripción del evento
Marca de tiempo	Durante las actividades de monitoreo y análisis de tráfico de red corporativo se detectó comportamiento anómalo asociado a malware.
Fase	Comando y Control (C2) con evidencia posterior de movimiento lateral dentro de la red interna.
Resultado	Se identificó comunicación entre múltiples hosts internos y dominios externos asociados a infraestructura maliciosa.
Dirección	Equipos comprometidos de la red interna establecieron conexiones salientes hacia direcciones IP externas controladas por el atacante.
Metodología	Uso de phishing dirigido, ejecución de malware y técnicas de pivoting para expandir el compromiso dentro de la red corporativa.
Recursos	Malware, dominios C2, direcciones IP externas, registros de logs, consultas WHOIS y tráfico de red monitoreado.

4.3 Análisis de Preguntas

4.3.1 ¿Quién es el adversario?

El adversario identificado en este incidente corresponde a una Amenaza Persistente Avanzada. De acuerdo con el diagrama de ejemplo del Modelo Diamante, podría tratarse de un grupo organizado (como APT28) cuya motivación principal se enfoca en el espionaje o el robo de información.

4.3.2 ¿Cuál es la capacidad utilizada?

La capacidad inicial consistió en una campaña de *phishing* dirigida estratégicamente para lograr el acceso. Una vez que el usuario interactuó con este correo, la capacidad técnica se centró en la ejecución de *malware* dentro del sistema comprometido. Adicionalmente, el diagrama detalla que estas capacidades suelen incluir troyanos, *exploits* y herramientas para mantener persistencia

4.3.3 ¿Qué infraestructura se emplea?

El atacante emplea dominios externos que forman parte de una infraestructura de *Command and Control*. La red evidenció que estos dominios resolvían hacia múltiples direcciones IP externas para mantener comunicación y control remoto. El modelo ejemplifica esta infraestructura como servidores VPS, direcciones IP específicas y dominios

4.3.4 ¿Quién es la víctima primaria?

La víctima primaria es un usuario de la red corporativa que cuenta con privilegios administrativos. Específicamente, el objetivo inicial fue el equipo o *host* que este administrador utilizaba cuando interactuó con el correo malicioso.

4.3.5 ¿Existe evidencia de movimiento lateral?

Sí y de hecho existe evidencia clara de movimiento lateral mediante la técnica de *pivoting*. El adversario utilizó el primer equipo comprometido como un puente, *proxy* o punto intermedio. Esto le permitió enrutar el tráfico malicioso evadiendo controles perimetrales para comprometer a una segunda víctima dentro de la red interna. Además, los registros de red mostraron conexiones salientes desde varios *hosts* internos, confirmando la expansión del ataque.

4.4 Relación con la Kill Chain

En esta sección se presenta la correlación de los eventos detectados en el análisis del incidente con las fases correspondientes de la Cyber Kill Chain. Esta estructura facilita la visualización del progreso del atacante dentro de la red corporativa.

Evento Detectado	Fase de la Kill Chain	Descripción Detallada del Evento
Envío de correo de phishing	Entrega (Delivery)	El atacante envía un correo dirigido a un usuario con privilegios administrativos para introducir el vector de ataque en la red.
Ejecución de malware en el host	Explotación/Instalación	El usuario interactúa con el archivo malicioso,

		permitiendo que el código se ejecute e instale persistencia en el sistema.
Detección de comportamiento anómalo	Detección Transversal	Punto de interrupción donde los sistemas de monitoreo identifican procesos no autorizados ejecutándose en memoria.
Conexión a dominios externos C2	Comando y Control (C2)	El malware establece conexiones salientes hacia múltiples direcciones IP externas para recibir órdenes del adversario.
Acceso a segunda víctima (Pivoting)	Acciones sobre Objetivos	Uso del primer host como proxy para realizar movimiento lateral y comprometer recursos adicionales en la red interna.

4.5 Hilos de actividad

En el análisis del incidente se identificó un escenario de ataque tipo Advanced Persistent Threat (APT), en el cual el adversario utilizó múltiples etapas para comprometer sistemas dentro de la infraestructura corporativa. Inicialmente, el atacante realizó una campaña de phishing dirigida hacia un usuario con privilegios administrativos, logrando la ejecución de malware dentro del primer host comprometido. Posteriormente, el equipo afectado estableció comunicación con servidores de Command and Control (C2), permitiendo al atacante mantener acceso remoto y control parcial del sistema. Una vez comprometido el primer host, este fue utilizado como punto intermedio o proxy para facilitar el movimiento lateral hacia una segunda víctima dentro de la red interna, ampliando así el alcance del ataque y la capacidad de persistencia del adversario.

Flujo del Ataque APT



4.5.1 Hilo 1 - Víctima 1

Este hilo representa el vector de acceso inicial y el compromiso de la víctima primaria. El adversario inicia el ataque mediante una campaña de phishing dirigida específicamente a un usuario con privilegios administrativos. Una vez que el usuario interactúa con el correo, se logra la ejecución del malware dentro del primer host. A partir de este momento, el equipo afectado establece comunicación saliente con los servidores de Command and Control (C2), lo que le permite al atacante mantener un acceso remoto persistente y tomar control parcial del sistema de la víctima.

4.5.2 Hilo 2 - Víctima 2

Este hilo ilustra la fase de expansión del ataque dentro del perímetro de la red corporativa. Aprovechando el nivel de acceso obtenido en el equipo del administrador, el adversario identifica y ataca a una segunda víctima, que puede ser otro equipo de usuario o un servidor crítico dentro de la red interna. Este segundo compromiso expande el alcance del ataque y

consolida la capacidad de persistencia del adversario en la infraestructura de la organización.

4.5.3 Relación entre ambos hilos (Pivoting)

La relación directa entre el Hilo 1 y el Hilo 2 se fundamenta en la técnica de pivoting o movimiento lateral. En lugar de atacar a la Víctima 2 desde el exterior, el atacante utiliza el primer host comprometido (Víctima 1) como un punto intermedio o proxy. Esto le permite enrutar su tráfico malicioso a través de una máquina interna de confianza, facilitando la evasión de los controles de seguridad perimetrales (como firewalls) y permitiendo el compromiso de sistemas adicionales en la red interna de manera sigilosa.

5. Conclusión

El análisis desarrollado mediante el Modelo Diamante y la metodología Cyber Kill Chain permitió comprender de manera estructurada el comportamiento del adversario y la evolución del incidente dentro de la infraestructura corporativa. A partir del escenario planteado, fue posible identificar los elementos fundamentales de la intrusión, incluyendo al adversario, las capacidades utilizadas, la infraestructura de Command and Control y las víctimas afectadas durante las distintas etapas del ataque.

La correlación de eventos evidenció cómo un ataque inicialmente dirigido mediante phishing puede evolucionar hacia un compromiso más amplio dentro de la red organizacional mediante técnicas de persistencia y movimiento lateral. Asimismo, el uso de la Cyber Kill Chain facilitó la clasificación cronológica de las actividades del atacante, permitiendo visualizar la progresión del ataque desde la entrega del malware hasta las acciones ejecutadas sobre los objetivos comprometidos.

De igual manera, el análisis de los hilos de actividad permitió identificar la relación entre las víctimas y comprender el uso de técnicas de pivoting para expandir el alcance del ataque dentro de la infraestructura interna. Esto demuestra la importancia de monitorear continuamente el tráfico de red, correlacionar eventos de seguridad y detectar conexiones anómalas hacia infraestructura externa asociada a servidores C2.

Finalmente, esta actividad permitió fortalecer la comprensión de metodologías de inteligencia y análisis de amenazas en ciberseguridad, demostrando que modelos como el Diamante y la Cyber Kill Chain constituyen herramientas fundamentales para la investigación de incidentes, la identificación de patrones de ataque y la toma de decisiones orientadas a la protección de los activos organizacionales.

Referencias

- Lockheed Martin. (2015). *Obtención de ventajas mediante la metodología Cyber Kill Chain aplicada a la defensa de redes*. Recuperado de [Cyber Kill Chain de Lockheed Martin](#)
- MITRE Corporation. (2024). *Framework MITRE ATT&CK*. Recuperado de [MITRE ATT&CK](#)
- National Institute of Standards and Technology (NIST). (2012). *Computer Security Incident Handling Guide (Special Publication 800-61 Revision 2)*. U.S. Department of Commerce.
- Caltagirone, S., Pendergast, A., & Betz, C. (2013). *The Diamond Model of Intrusion Analysis*. Center for Cyber Threat Intelligence and Analysis.